

Table of Contents

CSW — UK NCSC CAF Reference Design

Engineering reference design mapping Cisco Secure Workload (CSW) controls to the **UK NCSC Cyber Assessment Framework (CAF) v3.2**, used by UK Competent Authorities for NIS Regulations (OES) assessments and by the Cabinet Office GSG for GovAssure.

Audience: CSW administrators, Cisco SEs/SAs, and compliance engineers preparing CAF evidence for an OES Competent Authority or a GovAssure 3rd-party assessor.

Companion documents. See [caf-mapping.md](#) for the principle-by-principle crosswalk against sister frameworks already in this repo. See [CSW-UK-NCSC-CAF-Compliance-Report.md](#) for the customer-facing narrative. See [caf-igp-maturity-scorer.md](#) for the IGP rubric.

Status: Draft v1 — SME review required.

Reader's Guide

Who this is for. UK NIS Operators of Essential Services and GovAssure (Cabinet Office Government Security Group) teams, plus the Cisco SEs and compliance engineers preparing CAF evidence for a Competent Authority or a GovAssure assessor.

Questions this reference design helps you answer:

- *A3 — which workloads are inside the essential function, and which were deliberately left out?*
- *B5 — what actually enforces segmentation between those workloads, and can I show it still held on a given day?*
- *B1 — is the policy a document, or is it versioned and enforced?*
- *C1 — can I produce flow evidence with process context, not a sample of firewall logs?*
- *B2 and B6 — what must I point to outside CSW?*

Where to start. The applicability table below, then Phase 1 if the essential-function boundary is not yet a CSW scope. The principle-by-principle crosswalk is [caf-mapping.md](#).

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why a CAF assessor cares
Scope	Logical boundary for an essential function	The systems the assessment actually covers
Label	Tag assigning a workload to that boundary	Shows what was included and what was carved out
ADM	Application Dependency Mapping from observed traffic	The live flow diagram behind B5
Workspace	Policy container for one essential function	Where B1 policies are authored and versioned
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation is evidence before traffic is blocked
Denied Connections	Flows blocked by policy	Proof that B5 enforcement operates

Read next: [Compliance evidence playbook](#) · [About CSW](#)

Universal evidence workflow

Run these phases on the CAF essential-function boundary. The CAF-specific scope tree, labels, and artefact names are in the phases below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload is visible	Agents or connectors; CAF labels; essential-function scope	Days 1–10
2 — Baseline	Observed flows, not a diagram from memory	ADM for at least two business cycles	Days 11–28
3 — Policy	Designed isolation before enforce	Workspace; Simulation; exception register	Days 29–45
4 — Operate	Evidence between assessments	Enforce; monthly snapshot; quarterly pack	Ongoing

What CSW evidence does not replace

Identity and MFA (B2), staff training (B6), encryption and key management, backups and restore, perimeter and DDoS controls, and the OT device tier still need their own programmes. CSW covers the workload-resident slice: inventory, segmentation, flows, process context, vulnerability reachability, and change between snapshots.

CSW effectiveness for this framework

Applicability uses the repository standard. **Direct evidence** means the CSW artefact is material to one contributing outcome. In this mapping that is B5.b only. It does not mean the principle is Achieved. **Supporting evidence** means CSW supplements a control owned elsewhere. **Out of scope** means point the assessor somewhere else.

Principle	Applicability	What to show
A1 Governance	Supporting evidence	Posture summary for the board pack. Not roles, resourcing, or risk appetite.
A2 Risk management	Supporting evidence	Exposure and enforcement-gap trends for a risk process CSW does not own.
A3 Asset management	Supporting evidence	Sensor census and package inventory. Not people, power, or cooling.
A4 Supply chain	Supporting evidence	Observed vendor egress versus the supplier register.
B1 Service protection policies	Supporting evidence	Versioned workspace policy. Not the full policy, process, and procedure set.
B2 Identity and access	Out of scope	IdP and PAM. ISE can feed identity into policy; it does not replace them.
B3 Data security	Supporting evidence	East-west path control and plaintext-protocol deny. Not encryption or DLP.
B4 System security	Supporting evidence	Per-workload CVE and package inventory. Not

Principle	Applicability	What to show
B5 Resilient networks	Direct evidence for B5.b only	secure-by-design or patching. Host-firewall segregation and denied connections. Not backups (B5.c).
B6 Staff awareness	Out of scope	Training programme.
C1 Security monitoring	Supporting evidence	Host flow telemetry with process context. Not the log store or authentication logs.
C2 Proactive discovery	Supporting evidence	Unexpected-communication baselines. Pair with threat intelligence and EDR.
D1 Response and recovery	Supporting evidence	Containment and a forensic timeline. Not backup, RTO, or restore.
D2 Lessons learned	Supporting evidence	Snapshot delta that a lessons-learned review can use.

B5.b is the only direct evidence contribution. Twelve principles are supporting. B2 and B6 are out of scope.

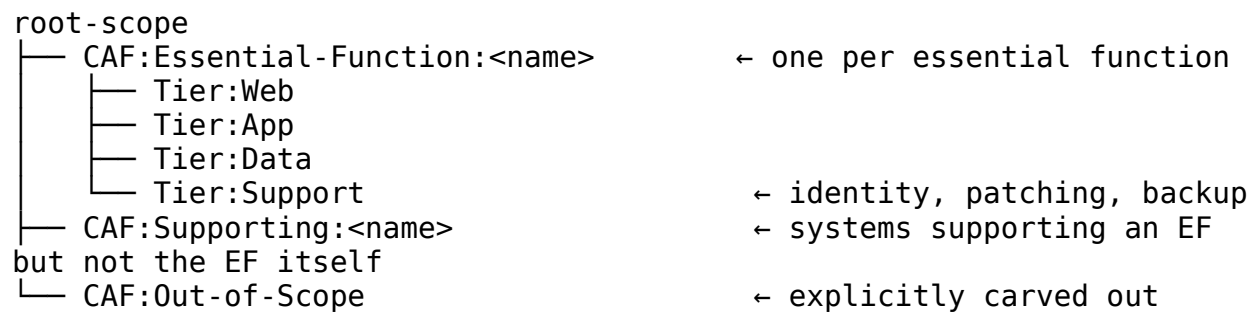
0. Prerequisites

- CSW cluster deployed and reachable; agents installed on all workloads in scope for the essential service.
- API key with capabilities: `sensor_management`, `app_policy_management`, `flow_inventory_query`, `software_inventory`, `user_data_upload`.
- Operations toolkit cloned ([CSW_POV_Template](#) or equivalent) — specifically `cluster_snapshot.py`, `generate_vuln_report.py`, `generate_forensics_report.py`, `generate_executive_report.py`.
- Scope hierarchy modelled with CAF scope in mind (see Phase 1 below).

1. Phase 1 — Scope definition

CAF applies to **essential functions** and the systems supporting them. The first engineering job is to translate "essential functions" into a CSW scope hierarchy an auditor can read.

Recommended CSW scope pattern



Workloads inside `CAF:Essential-Function:*` are "in scope" for the CAF assessment. The explicit `CAF:Out-of-Scope` scope exists so an assessor can see what was deliberately excluded and why.

Labels / tags to apply (per workload)

Label	Example values	CAF principle this feeds
caf_essential_func tion	electricity_distri bution, patient_record_sys tem	A3, B5
caf_tier	web, app, data, support, ot_adjacent	B5, B1
caf_data_classific ation	ePHI, PII, operational, public	A3, B3
caf_criticality	critical, high, medium, low	A2
caf_owner_team	payments_eng, clinical_apps	A1, A3
caf_regulator	ofgem, ofcom, dwi, caa, dft, dhsc, govassurance	—

Push these as annotations via `user_data_upload` from your CMDB.

Deliverable from Phase 1

- `scope-model.md` — explains the scope tree and the labels, signed off by the CAF scoping SME.
 - `scope-workloads.json` — snapshot of which workload lives in which CAF scope (produced via `cluster_snapshot.py`).
-

2. Phase 2 — Policy authoring per CAF principle

Policies live inside CSW workspaces. One workspace per essential function is the recommended pattern.

Policy design per principle

- **B5 (segmentation):** Default-deny between CAF essential-function scopes; explicit allows only for documented data flows; cross-tier flows restricted to the specific ports/processes ADM identified. For IT/OT separation, add an explicit `CAF:Essential-Function:* → CAF:OT-Zone:*` deny with narrow exceptions.
- **B1 (policies & processes):** Every policy carries a human-readable description; version tagged with change ticket; owner labelled.
- **B4 (system security):** Policies that deny known-vulnerable-service ports (telnet, old SMB, plaintext SNMP) across all CAF scopes.
- **B3 (data security — in transit):** FIPS-aligned deny of plaintext protocols for workloads tagged `caf_data_classification=PII` or stricter (see [FIPS 140 reference design](#) for pattern).

ADM → simulate → enforce workflow

1. Run ADM on each `CAF:Essential-Function:*` workspace to get a baseline policy proposal.
2. Review in CSW UI; adjust against the documented authorised data flows for the essential function.
3. **Simulate** for at least two full business cycles (typically 2 weeks) before enforcement. Simulation reports become evidence for A2 ("continuous, not annual").
4. Enforce in staged rings: `Tier:Support → Tier:Web → Tier:App → Tier:Data`.
5. Keep ADM version history as change log — this is B1 evidence.

Deliverable from Phase 2

- `policies-authored.json` (via `download_policies.py`) — the current policy set per workspace.
 - `simulation-report-<yyyy-mm-dd>.html` per essential function — pre-enforcement evidence of what would be allowed vs rejected.
 - `policy-change-log-<yyyy-mm-dd>.md` — ADM versions and the human-approved changes between them.
-

3. Phase 3 — Evidence collection per CAF Objective

Automate the following so evidence is produced on a cadence, not scrambled for the audit.

Monthly (per cluster)

<code>python3 cluster_snapshot.py</code>	<i># A3, A2, B4 (point-in-time inventory + posture)</i>
<code>python3 generate_vuln_report.py</code>	<i># B4, A2 (CVE inventory tied to</i>

```
workloads)
python3 generate_forensics_report.py # C2 (MITRE technique coverage)
python3 download_flows.py --hours 720 # C1 (30-day flow archive)
python3 generate_executive_report.py \
  --snapshot-latest \
  --prepared-for "<Essential Function Owner>" \
  --prepared-by "SecOps" # A1, A2 governance telemetry
```

Weekly (per cluster)

```
python3 cluster_delta.py \
  --from snapshots/snapshot-<prev-week>.json \
  --to snapshots/snapshot-<this-week>.json # D2 improvement
evidence
```

Per enforcement change

```
python3 download_policies.py # B1 change log
```

Mapping evidence artefacts to CAF Objectives

CSW artefact	CAF Objectives served
snapshot-*.json	A2, A3, A4 (partial), B4
vulnerabilities-*.csv	A2, B4
policies-all.json + ADM version history	B1, B5
conversations-*.json / flows-*.csv	C1, B5 (verification), D1 (IR timeline)
forensics-posture-*.html	C2
simulation-report-*.html	A2, B1
executive-summary-*.html / .md	A1, A2
cluster-delta-*.md	D2

4. Phase 4 — Quarterly CAF evidence pack

A GovAssure or OES Competent Authority submission typically wants an evidence pack covering each CAF principle. Pre-stage the files monthly; assemble the pack quarterly.

Pack structure

```
caf-evidence-pack-<yyyy-qq>/
├── 00_overview.md ← executive summary + scope
├── attestation
│   ├── A1_Governance/
│   ├── A2_Risk_Management/
│   ├── A3_Asset_Management/
│   └── A4_Supply_Chain/
```

```

|— B1_Policies_Processes/
|— B2_Identity_Access/           ← pointer to IdP evidence (no
CSW output)
|— B3_Data_Security/
|— B4_System_Security/
|— B5_Resilient_Networks/
|— B6_Staff_Awareness/         ← pointer to training evidence
|— C1_Security_Monitoring/
|— C2_Proactive_Discovery/
|— D1_Response_Recovery/
|— D2_Improvements/
|— 99_disclaimers_and_pairings.md

```

See [caf-evidence-pack-template.md](#) for exactly what file goes in each folder.

5. Common assessor questions and the CSW answer

Question	CSW evidence
<i>"Prove the control still held last Tuesday, not just today."</i>	Monthly <code>snapshot-*.json</code> and flow archive — point-in-time attestation.
<i>"How do you know you'd see an attacker moving laterally?"</i>	Flow telemetry + rejected-flows report + MITRE forensics coverage.
<i>"How do you measure improvement since the last assessment?"</i>	<code>cluster_delta.py</code> output + <code>executive-summary</code> trend.
<i>"What enforces the segmentation — is it just a firewall rule you hope stays?"</i>	Policies are enforced in-kernel on every host (nftables / WFP); CSW continuously verifies.
<i>"How do you handle supplier access?"</i>	Scope-tagged egress flows; vendor-package inventory; pair with TPRM.
<i>"What about identity?"</i>	Explicit: CSW is not an IAM tool. Point to IdP + PAM evidence.

6. SE / SA conversation starters

Lift from the repo's [SE compliance role-play](#) but tailored to a UK assessor conversation:

1. *"Which of your essential functions is being assessed first — and how many workloads sit inside its boundary?"* → scopes problem to real numbers.
2. *"Who is your Competent Authority for this programme (Ofgem? DWI? GSG?) and what have they flagged in prior assessments?"* → anchors conversation in regulator language.
3. *"Can you show which systems that support the essential function are separated from other business systems, and which connections were denied?"* → this is B5.b. CAF does not ask for a Purdue model.

4. *"When you need to tell your Competent Authority that control X still held last Tuesday, where does that evidence come from?"* → surfaces continuous-vs-annual pain, where CSW shines.
-

7. Known limitations and pairings

- **B2 (Identity):** CSW cannot satisfy. Pair with IdP + PAM. Use [ISE integration](#) for identity-aware segmentation (identity assertion from ISE).
 - **B6 (Training):** Out of scope.
 - **D1 (Backup/DR):** CSW contains blast radius; it does not restore services. Pair with backup/DR platform.
 - **OT device tier:** CSW does not run on PLCs/RTUs/IEDs. Pair with Cyber Vision / Claroty / Nozomi / Dragos.
 - **Perimeter / DDoS:** CSW is east-west only. Pair with Secure Firewall and DDoS service.
-

Related frameworks

Reuse the engineering detail already written for the sister control, then attach it to the CAF principle in [caf-mapping.md](#):

- [NIS2](#) — A2, A4, and incident timelines
 - [ISO/IEC 27001:2022](#) — A.8.20–A.8.22 for B5
 - [NIST CSF 2.0](#) — outcomes language across A–D
 - [NIST SP 800-53](#) — AC-4 / SC-7 for B5
 - [CIS Controls v8.1](#) — inventory, vuln, and monitoring
 - [IEC 62443](#) — zones and conduits for B5
 - [NIST SP 800-82](#) — IT side of an IT/OT boundary
 - [MITRE ATT&CK](#) — C2
 - [DORA](#) — supplier egress (A4) and incident dossier (D1)
 - [FIPS 140](#) — plaintext-protocol deny for B3
-

Disclaimer

Draft v1. Requires SME review against the current CAF text (v3.2 at time of authoring) and against your Competent Authority's expectations before relied upon in a formal assessment. See [repository disclaimer](#).